

Quarterly Threat Report: First Quarter, 2026

Executive Summary

The first quarter of 2026 started with a lull and ended with a bang. Early seasonal slowdowns across ransomware deployments, infostealer downloads, and other observed cybercriminal activity gave way to high-profile announcements, politically linked cyberattacks, and AI developments that shaped the cyber threat landscape this quarter.

What started as a single misconfigured automation workflow became **one of the most consequential developer supply chain campaigns on record**. Threat actor group TeamPCP used an AI-assisted bot called hackerbot-claw to gain an initial foothold into Aqua Security's Trivy vulnerability scanner, then used stolen credentials to spread across Checkmarx's KICS security scanner, the LiteLLM AI library, and more than **66 additional software packages**. The credentials harvested across this campaign reached beyond developer ecosystems. Cisco confirmed over

300 internal repositories were stolen, the European Commission was confirmed as a victim by CERT-EU, and AI data startup Mercor described itself as **one of thousands of companies impacted through the LiteLLM compromise**. Beazley Security Labs analyzed an emerging TeamPCP-Vect ransomware partnership as a potential monetization path for the stolen credentials and obtained access to the Vect affiliate panel.

In parallel, Anthropic's announcement of Project Glasswing and the Mythos model generated significant industry attention and briefly moved cybersecurity stocks. The capabilities of Mythos are real, but for anyone who has been tracking the progress of frontier models over the last year, Mythos is the next step on a curve rather than a sudden leap. Opus 4.6, Opus 4.7, and the latest OpenAI models have all shown steady, **measurable improvements in vulnerability discovery and reliability on cybersecurity tasks**. As Beazley Security analyzed earlier this year in [Security Magazine](#), these models have created an efficacy asymmetry in cybersecurity: attackers can afford to fail repeatedly while defenders cannot. Mythos moves that curve further, but it does not move it in a new direction.

The implications of Mythos for defenders are not new, but the urgency is. AI has been accelerating exploitation timelines and **Q1 saw a significant rise in zero-day vulnerabilities being abused in the wild**. Teams that are not already patching critical vulnerabilities within hours of public disclosure, regardless of asset criticality, need to close that gap now. Additionally, **when a zero-day is actively exploited, patching alone is not enough**. Organizations need to treat exposure during the exploitation window as a potential compromise and do the forensic work to validate their environment before moving on. Beyond patching and response, organizations need to build defense in depth that explicitly assumes internet-facing systems and web applications will eventually be exploited. That means layered controls, strong detection at the host and network level, and response playbooks that don't start from the assumption of a clean environment. Many of the vulnerabilities Mythos has publicly surfaced aren't reliably exploitable in practice, as researchers were quick to note following the announcement. But the trend is clear and compression in timeline to remediate exposure is real. The organizations best positioned to weather it are those that have stopped treating zero-day events with a legacy patch program as the primary objective and started optimizing for rapid detection and response to contain any signs of post-exploitation activity.

An incident impacting medical device manufacturer Stryker, claimed by Iranian-linked Handala Group, marked one of the most destructive attacks disclosed this quarter. The group gained administrative access to Stryker's Microsoft Entra environment and weaponized Microsoft Intune's remote wipe functionality, destroying **data across more than 200,000 systems and 79 offices worldwide**. Demonstrating how cloud management platforms can be weaponized in the

hands of a capable threat actor, the attack required neither conventional malware nor lateral movement. All the threat actor needed was to compromise the right administrative credentials.

Vulnerability activity continued to trend upward with **over 15,200 new vulnerabilities** publicly disclosed and **40 confirmed being actively exploited in the wild**, a nearly **43% increase** compared to Q4. Beazley Security Labs published 15 critical security advisories in Q1, a **15% increase** over the prior quarter. AI-powered vulnerability discovery tools are a contributing factor, with bug bounty programs reporting a significant increase in AI-assisted submissions.



Ransomware activity remained consistent through Q1, with credential-based initial access continuing to drive most incidents. Compromised credentials paired with exposed remote access services accounted for **74% of ransomware** intrusions investigated by Beazley Security this quarter. However, we did see a notable trend emerge in Q1: a growing subset of threat actors skipped encryption entirely, opting for data theft and extortion for ransom.

Business email compromise remained one of the most frequently reported incident categories, with vendor impersonation driving the majority of successful compromises. In approximately **53% of BEC cases** Beazley Security responded to, organizations had MFA enabled, reinforcing that modern credential-based attacks remain effective even in environments with basic MFA in place.

Beazley Security's MXDR telemetry reflected a shift this quarter, with a **resurgence of activity tied to ClickFix-style social engineering attacks and SEO poisoning campaigns** that attempt to place malware directly on endpoints, bypassing traditional browser and proxy controls.

This report explores how these trends played out across observed incidents and what they signal for the threat landscape going into Q2.

Q1 2026 Takeaways

- While 2025 saw an ever-shortening "time to exploit" window for **discovered** vulnerabilities, 2026 begins with a substantial rise in the **quantity** of critical vulnerabilities threat actors appear to be crafting exploits for.
- TeamPCP's AI-assisted developer supply chain campaign compromised Trivy, Checkmarx KICS, and LiteLLM in a multi-stage attack, spreading credential-stealing malware across more than 66 packages and **reaching downstream victims such as Cisco and the European Commission**.
- BSL documented [TeamPCP's partnership with the Vect ransomware operation](#) and how Vect is actively monetizing stolen credentials through ransomware deployments.
- Anthropic's latest frontier model Mythos demonstrated a meaningful advance in AI-assisted vulnerability discovery. While the capability is real and has accelerated, it does not change the

fundamental defensive calculus. Speed of response and defense in depth remain the right answer.

- CISA Known Exploited Vulnerabilities (KEV) catalog sees a **43% increase**, driven in part by AI-assisted bug discovery. The window between vulnerability disclosure and active exploitation continues to shrink.
- Iranian-linked cyberattacks surface amid rising geopolitical tensions, including a destructive Handala Group operation that destroyed data on **more than 200,000 systems** at Stryker by weaponizing Microsoft Intune's remote wipe functionality.
- Compromised remote access credentials remained the leading cause of ransomware deployments investigated by Beazley Security in Q1, accounting for **74% of intrusions**. Data exfiltration-only extortion continued to grow as a pattern among affiliate operators.
- Beazley Security MDR telemetry shows a return of ClickFix and SEO poisoning campaigns delivering malware directly to endpoints.



Observations in the Threat Landscape

TeamPCP Attacks Developer Ecosystem & Supply Chain

What began with a single misconfigured automation workflow in late February 2026 escalated into one of the most consequential developer supply chain campaigns we've observed. In this campaign, a threat actor named "TeamPCP" deliberately targeted developer and pipeline security tooling because these solutions often run with elevated privileges and have access to sensitive credentials. Throughout the campaign, each victim became the next pivot point as TeamPCP successfully compromised Aqua Security's Trivy vulnerability scanner, Checkmarx's KICS static analysis tool, the widely used LiteLLM AI library, and more than 66 additional packages. Confirmed downstream victims include Cisco, the European Commission, and AI data startup Mercor. Mandiant estimated **over 1,000 enterprise SaaS environments were impacted across this attack campaign**.

The incident represents a direct escalation of the developer supply chain attack pattern Beazley Security Labs highlighted in prior reporting on the [Shai-Hulud](#) campaigns, which demonstrated how self-propagating, credential-stealing malware could weaponize the npm ecosystem at scale. Where Shai-Hulud relied on compromised npm maintainer accounts to spread, TeamPCP combined AI-automated initial access, incomplete breach containment, and the abuse of trusted security tooling to achieve propagation across multiple victims and significantly more impact than Shai-Hulud.

TeamPCP operated across parts of the software development ecosystems, including Github, Docker, npm, and PyPI to execute this attack, compromising security tools trusted by thousands of organizations. We describe in detail how the attack was able to cascade in the phases below:

Phase 1: hackerbot-claw: An AI agent opens the door

The campaign began with an autonomous AI agent. A GitHub account named "hackerbot-claw" created February 20, 2026, scanned public repositories for misconfigured GitHub Actions workflows that allowed untrusted pull request code to execute with full repository permissions and access to secrets. The AI powered bot automatically identified, exploited, and exfiltrated at scale.

On February 28, hackerbot-claw exploited a misconfiguration in Trivy's GitHub repository and stole a privileged "Personal Access Token" tied to the "aqua-bot" service account, which had access to more than 30 workflows across the Aqua Security GitHub organization. Aqua Security discovered the breach and attempted to rotate credentials, but their containment process was incomplete, leaving residual access that TeamPCP would use in the coming weeks.

Phase 2: Security scanners abused for credential theft

On March 19, TeamPCP leveraged access that survived Aqua Security's incomplete credential rotation and published malicious code to nearly all versions of the Trivy scanner. The group published a backdoored Trivy binary that included malware called "TeamPCP Cloud Stealer" to GitHub Releases, Docker Hub, and several other repositories followed by additional malicious images in the days that followed.

The Trivy security scanner is designed to run inside CI/CD pipelines, and by planting the malicious payload within the scanner, the code could run silently to dump process memory, harvest SSH keys, cloud provider credentials, Kubernetes tokens, and API keys. The stealer then encrypted the stolen credentials and exfiltrated them through an attacker-controlled Cloudflare Tunnel to blend in with normal developer traffic. Even with the stealer implanted, Trivy continued to run scans as expected, and pipelines completed successfully.

Any GitHub Actions workflows that referenced compromised Trivy "tags" resolved to the malicious version of the scanner and over **10,000 GitHub workflows reference trivy-action** at the time of publishing. As with the Shai-Hulud campaigns, stolen tokens were reused to spread the malware downstream, reaching Checkmarx, LiteLLM, the Telnyx SDK, and more than **66 additional software packages** across the npm and PyPI package ecosystem.

Phase 3: Additional attacks against Checkmarx and LiteLLM

On March 23, TeamPCP compromised a Checkmarx service account used to publish official releases to their repo. The group used that access to hijack all 35 tags of the "kics-github-action" repository and poison a version of the "ast-github-action" static code analysis tool. The malicious payload shared the same encryption key as the Trivy stealer, linking the activity to TeamPCP. Malicious images were also discovered pushed to the official Checkmarx Docker Hub repositories. Shortly after the compromise, another threat actor group known as "Lapsus\$" leaked Checkmarx source code, API keys, database credentials, and employee data on their extortion leak site. Checkmarx later confirmed the leaked data originated from their GitHub environment.

On March 24, LiteLLM became another downstream victim of the Trivy attack. BerriAI, LiteLLM's creator, used Trivy for security scanning in their own CI pipeline, and when the poisoned trivy-action ran in the environment, it was able to exfiltrate the PyPI publishing token for the LiteLLM maintainer account. TeamPCP used that token to publish malicious versions directly to PyPI, their managed python package repository. The packages were quarantined within hours, but given LiteLLM's download volume, thousands of organizations and developers ran the compromised versions automatically before removal.

LiteLLM is one of the most widely used libraries in the AI development ecosystem, with approximately **95 million monthly downloads**. LiteLLM functions as an API gateway that brokers connections to AI services from providers including OpenAI, Anthropic, Google, and Azure. Organizations use it to centralize and manage API keys across every AI service they run. This makes LiteLLM a particularly interesting target, as the library is also an embedded dependency in other AI agent orchestration frameworks and tools, meaning many organizations running the compromised versions may not have known LiteLLM was present in their environment.

Downstream Impact

TeamPCP weaponized the credentials harvested by this campaign to extend access across downstream environments. Cisco confirmed its internal development environment was breached through the Trivy attack, with source code from over **300 internal GitHub repositories stolen**, including source code for AI-powered products and customer code belonging to banks and US government agencies. CERT-EU separately [confirmed](#) the European Commission fell victim to the attack, with TeamPCP leveraging a single stolen AWS API key from their compromised Trivy instance to gain access into the environment. AI hiring startup Mercor confirmed it was among those affected by the LiteLLM compromise, with Lapsus\$ claiming approximately 4 terabytes of exfiltrated data including source code and identity verification documents. Mercor publicly described itself as "one of thousands of companies" impacted.

Beazley Security Labs documented potential monetization paths tied to this and future TeamPCP campaigns. BSL gained insider access to the Vect 2.0 ransomware affiliate panel and observed

Vect's partnership with TeamPCP as announced publicly on BreachForums. The actors stated an explicit intent to "jointly deploy ransomware against organizations affected by the recent supply chain attacks." Vect is developing a turnkey RaaS platform for exactly this kind of follow-on operation. The first [confirmed](#) Vect ransomware attack using TeamPCP-sourced credentials followed shortly after the "partnership" was announced. In April 2026, Vect distributed affiliate keys broadly to registered BreachForums users, opening up the platform to a growing list of affiliates and potentially increasing exposure of credentials harvested by TeamPCP.



Beazley Security Labs will continue to monitor for ransomware and extortion activity attributed to the partnership between TeamPCP, Vect, and other threat actors. For deeper insight and technical analysis of the Vect 2.0 platform and locker capabilities, along with the TeamPCP partnership, see [Vect 2.0: An Insider Perspective on the New Ransomware Variant](#).

What This Means for Defenders

The TeamPCP campaign demonstrates a deliberate attacker playbook to target the tools developers and security teams trust. Security scanners and CI/CD actions are granted broad, often elevated privileges by design. In this campaign, the most security-conscious organizations (those scanning every build) had the greatest exposure.

Security teams need to adjust to the reality that tools we trust and have integrated into our pipelines are being actively used against us. In response, it's critical that organizations take actions to reduce risk and the blast radius. CI/CD pipelines should pin external GitHub Actions and package dependencies to specific Git commit SHA hashes rather than "version tags," which can be silently redirected without any visible change to workflow files. Second, any organization that ran Trivy, used trivy-action or setup-trivy, or installed LiteLLM during the March 2026 exposure windows should treat those environments as potentially compromised and rotate all CI/CD secrets and cloud credentials. Third and most importantly: incomplete incident response is its own vulnerability. The March 19 attack was only possible because credentials survived Aqua Security's initial rotation.

Anthropic Mythos and the Accelerating AI Vulnerability Discovery Trend

While the TeamPCP Trivy breach made waves in the "agentic offensive AI" space, it was not the only AI related event to gain widespread attention this quarter. On March 26th, Fortune published an article on [a pending blog post](#) from Anthropic staged to announce a new AI model (known as "Mythos") that prompted industry attention and triggered market reactions in cybersecurity-related stocks.

Anthropic's own testing showed that Mythos Preview found thousands of previously unknown vulnerabilities across every major operating system and web browser, including a 27-year-old flaw in OpenBSD that had survived decades of human and traditional automated source code security review and another 16-year-old bug in FFmpeg that had been hit by other automated testing tools five million times without detection.

As with similar high-profile developments in the agentic AI space, days of sober analysis from technical experts followed the announcement. A researcher named xarkes who [studied the reported Firefox bugs](#) found that they included several that were not practically exploitable by a threat actor. Security Researcher [Marcus Hutchins noted](#) that many of the memory corruption vulnerabilities were what are called "null pointer dereference" bugs, which are generally too unreliable or unexposed to be practically exploitable.

The more important takeaway is not whether every finding is immediately weaponizable, but what Mythos initial benchmarks signal about the trajectory of AI-discovered vulnerabilities. For example, the Mythos model scored 83.1% on CyberGym's vulnerability reproduction benchmark as compared to 66.6% for Opus 4.6, a considerable leap in performance from Anthropic's prior leading model. Mythos did not autonomously discover new vulnerability classes, and it found the same categories of bugs that approaches like static code analysis have always targeted. What has continued to compress through iterations is the speed, scale, and level of expertise required to find (and weaponize) such bugs. **This is a trend Beazley Security has been tracking.**

As we analyzed earlier this year in [Security Magazine](#), AI models have created an efficacy asymmetry in cybersecurity: for a threat actor, an 80% success rate is an advantage because a failed attempt costs time and tokens. For defenders, the same error rate carries a far higher consequence. With the information publicly released by Anthropic, Mythos is a significant step on that curve. It does not change the need to focus on vulnerability remediation; it accelerates the pace needed to action affected systems in an environment.

Organizations best positioned to manage this shift are those with strong defense in depth controls and the operational capacity to treat zero-day exposure as a potential compromise, not just a patching event. As AI accelerates vulnerability discovery and exploitation, the window between disclosure and active abuse will continue to shrink. Organizations that can quickly determine whether they were exposed, assess whether that exposure was leveraged, and perform the forensic validation required to validate environment integrity will be better positioned than those that treat this purely as a patch management problem.

Agentic AI in Cybercrime Communities

While announcements like Mythos create news hype and influence market fluctuations, they represent the cutting edge of what the industry and researchers might be capable of, but not yet what might be practically proven or accessible to the common cybercriminal. To get a better view, Beazley Security Labs conducted research across a broad range of monitored cybercriminal forums, including both invite-only and public Russian-speaking dark web markets. This visibility into criminal markets gives us an "on the ground" understanding of how cybercriminal threat actors are currently integrating AI into their operations, separate from the media hype.



What we found in Q1 was a market still largely focused on automating and accelerating existing attack patterns rather than enabling fundamentally new ones. The most common AI-powered tooling advertised was oriented toward web application attacks:

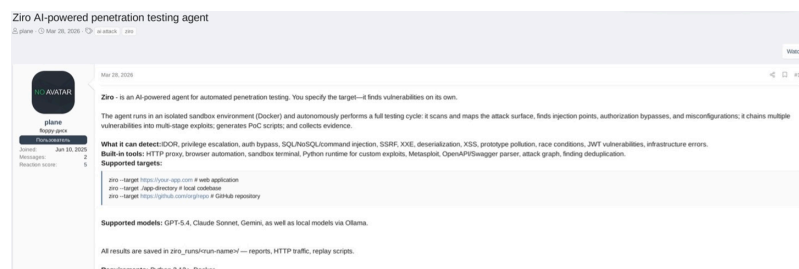


Figure 1: Cybercriminalad for AI pentester (translated)

This is not a coincidence and applying commodity grade AI models against this attack vector can help lower barrier to entry for a bad actor. Modern web applications ship substantial amounts of JavaScript source code directly to a client's browser, making the code publicly accessible to anyone who visits the page. Unlike internal systems or backend infrastructure, this client-side code can be accessed freely by AI models to discover vulnerabilities and misconfigurations at a speed and scale no human researcher can match, which is exactly what the tooling we observed is attempting to do.

Like legitimate companies, threat actors are trying to use AI to empower internal operations like data mining and processing. We found a cybercriminal group offering a service that ingests stolen data sets and uses AI to surface the highest-value information for extortion purposes, identifying which documents and records would create the most pressure on a victim to pay. Access was being sold for \$1,000:

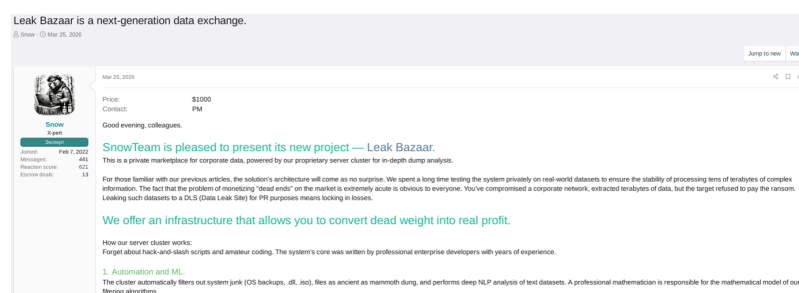


Figure 2: AI powered data leak verification service (translated)

This trend is something that BSL and our team expected and flagged in 2025. In our [Top Threats for 2025 webinar](#), we predicted that rather than threatening to dump terabytes of stolen data wholesale, attackers would use large language models to find the "top 20 most devastating documents in a stolen set and threaten to publish specifically those". Seeing it advertised as a commercial service on criminal markets in Q1 confirms the direction. As data theft continues to be a dominant ransom and extortion pattern, AI-assisted triage of stolen data will likely become standard practice among large tier operators, compressing the time between data theft and targeted extortion pressure.



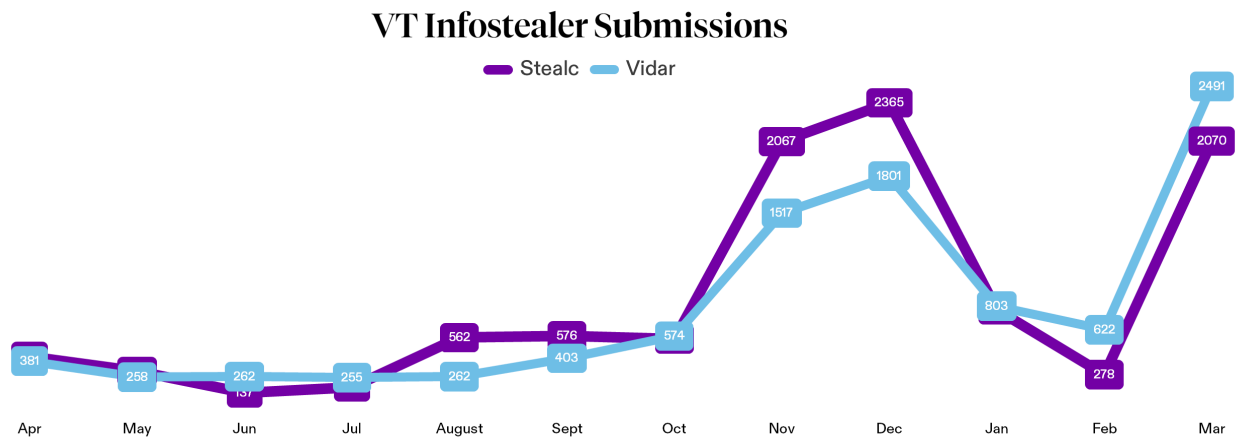
Our research shows that AI hasn't yet given commodity threat actors novel capabilities, it's just lowered the bar for existing ones. A web application vulnerability scanner that used to require a skilled researcher is now powered by AI and runs itself. For defenders, this reinforces the fact that cybersecurity fundamentals are just as important as they have always been.

Infostealer Trends: Holiday Season Brings a Lull in Activity

The winter holiday season traditionally sees day-to-day business productivity slacken as employees take extended time off to be with family and friends. It's been common experience in cyber threat intelligence (CTI) circles that threat actor groups show a similar pattern, and our data support this from multiple angles in Q1.

In the infostealer world, we reported [last quarter](#) on the shakeup caused by [Operation ENDGAME](#). This multi-agency international enforcement significantly disrupted the operations of the Lumma Stealer and Rhadamanthys malware families, creating an opportunity for StealC and Vidar to fill demand.

We use VirusTotal submission counts alongside our MDR telemetry to assess the adoption and weaponization of various infostealer families over time. While StealC and Vidar saw an expected rise in numbers end of Q4, this rise was followed by a significant dip in the start of Q1 with a sharp rise at the end of the quarter.



We believe the lull in sightings from StealC and Vidar over Q1 resulted not from law enforcement activity but from decreased activity over the holiday break. Neither point of contact for each family reported any problems or issues on the cybercriminal forums that Beazley Security Labs monitors but instead showed a reduced frequency of posts in January and February. For example, StealC user account for sales and updates posted only two generic updates in December and January which they typically post multiple times each month:

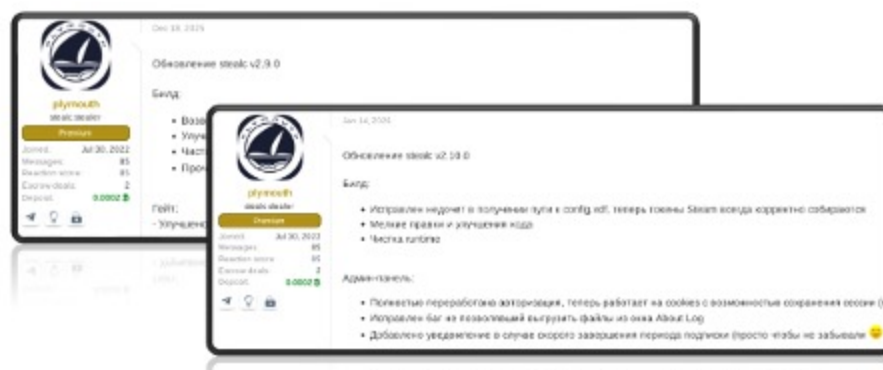


Figure 4: Reduced post frequency from StealC vendor

Once the holiday months had passed, submission counts in Beazley Security's collected telemetry shows that infections returned to previously observed numbers. We assess that these, and other families, will see increased usage as initial access vectors for breaches later this year.

Iran-Linked Handala Group Abuses Microsoft Intune to Destroy Data

In March, US medical device manufacturer Stryker [disclosed](#) a cyber incident that resulted in widespread global disruption to its environment. The Fortune 500 company reported experiencing outages across its systems starting March 11, 2026, affecting 79 of its offices around the world, **resulting in over 200,000 systems being remotely wiped**. The scale and operational disruption of the attack marked one of the most destructive publicly disclosed cyberattacks observed this quarter.

The hacktivist group Handala, linked by researchers to Iran's Ministry of Intelligence and Security (MOIS), claimed responsibility for the attack. The group, tracked by security organizations as "Red Sandstorm" or "Banished Kitten," originally emerged in 2023 and has a history of disruptive operations targeting Israeli and international organizations. The attack against Stryker appears to be politically motivated in an attempt to disrupt operations of a well-known firm in retaliation for hostilities against Iran.

Public reporting of the attack indicates the group gained administrative access in Stryker's Microsoft Entra environment and weaponized Microsoft Intune's remote wipe functionality. This allowed them to destroy data across corporate systems, servers, and enrolled endpoints, including personal employee devices enrolled in bring your own device (BYOD) management.

Handala publicly claimed **exfiltration of approximately 50 terabytes of data** during the attack, suggesting that collection and data theft may have been occurring weeks before the mass "w" command was issued. Security researchers have also noted that prior Handala operations have originated from SpaceX [Starlink IP ranges](#), likely enabling the group to maintain connectivity during sustained periods of internet blackouts within Iran, hindering basic geographic IP blocking and monitoring.

Leveraging Intune's wiping technique at such scale was a novel living-off-the-land attack exploiting a widely used cloud management plane. Once the attackers had valid global admin credentials, every Intune enrolled device was reachable and vulnerable, without the need for additional lateral movement. Unlike modern ransom and extortion-driven attacks played out for monetary gains, the attack prioritized destructive impact and public exposure amid heightened geopolitical tensions.

For organizations running Microsoft Intune and Entra, this attack highlights the importance of protecting global admin credentials with phishing-resistant MFA and Privileged Identity Management (PIM), restricting remote wipe authority to specific roles with enforced secondary approval, and flagging bulk device management commands as high-severity alerts warranting immediate review.

Vulnerability Trends and Overview

Beazley Security Labs continuously monitors the threat landscape to identify high-impact vulnerabilities as part of our mission to reduce risk, and to support our Exposure Management platform. We publish advisories for the most critical of these vulnerabilities, providing organizations with technical analysis and remediation recommendations.

In Q1 2026, **over 15,200 new vulnerabilities** were publicly disclosed, with about **3,900 of them considered high risk**, meaning they could be exploited remotely with potential to cause harm if unpatched. This is an increase **from about 2,200** in Q4 2025.

In response to the increase in high impact vulnerabilities, BSL published 15 security advisories in Q1 2026, **a 15% increase over the previous quarter**. While BSL observed a seasonal slowdown in

CVE volumes over the winter holidays, volume increased sharply near the end of Q1. In March alone, BSL published 7 advisories.

Among these, **40 vulnerabilities were confirmed** to be actively exploited in the wild, according to the US Cybersecurity and Infrastructure Security Agency (CISA). These "Known Exploited Vulnerabilities" (KEVs) are especially important because they represent real-world threats and impacts.

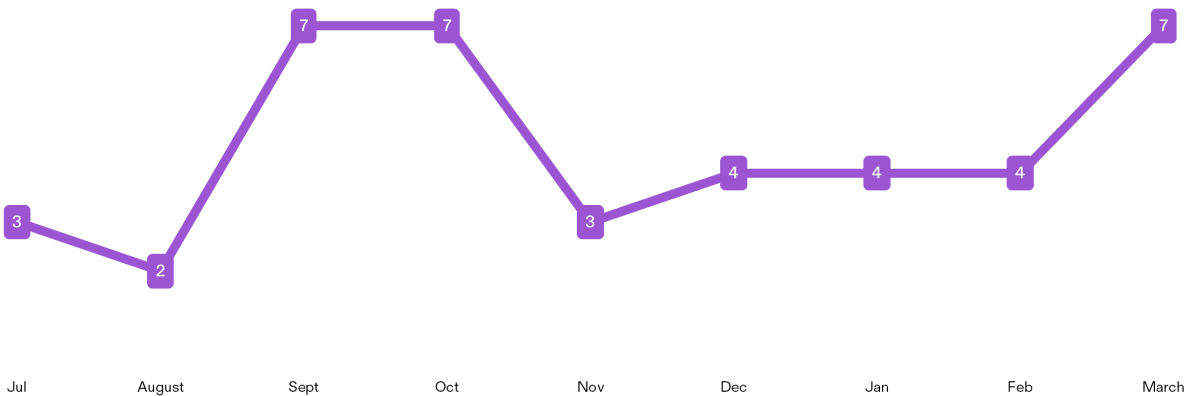


Vulnerability Trends	Q1 2026	Change from Q4 2025
New CVEs published by NIST	15,243	+18.5%
CVEs added to CISA KEV	40	+42.9%
Critical 0-Day advisories published by BSL	15	+15.4%

*Critical BSL advisories are made publicly available [here](#).

The first quarter saw continued increases across the board in newly published vulnerabilities, vulnerabilities assessed by BSL to be high risk, vulnerabilities critical enough for BSL to publish advisories, and vulnerabilities added to CISA KEV. The last category (CVEs added to CISA KEV) had a significant 43% increase over last quarter. Over half of the increase is from a population of vulnerabilities found in "edge devices" such as firewalls and VPN endpoints. Another sizable portion of the vulnerabilities added to KEV were from a particularly impactful "patch Tuesday" from Microsoft in February, where at least 5 patched vulnerabilities were added to the CISA KEV list.

BSL Advisories



High-profile Breaches and Zero Day Vulnerabilities Exploited in the Wild



- Ivanti vulnerabilities reported in EPM and EPMM:** Ivanti reported critical vulnerabilities in both their Endpoint Manager Mobile ([EPMM](#)) and Endpoint Manager ([EPM](#)) products in Q1. Both products are commonly found deployed as directly internet accessible, meaning the vulnerabilities could be used by threat actors to gain initial access into organizations' networks. The EPMM CVEs were discovered to be already actively exploited in the wild at time of discovery, and [further investigation from Rapid7](#) found them to have been used by Iranian state-affiliated threat actors in cyberattack campaigns.
- High-profile supply chain breaches targeting the developer ecosystem:** Q1 saw several high-profile supply chain compromises targeting the developer ecosystem, with varying degrees of reach and impact. The most significant was the TeamPCP campaign covered in detail above, which spread from Aqua Security's Trivy scanner to Checkmarx KICS, LiteLLM, and more than 66 additional packages, with confirmed downstream breaches at Cisco, the European Commission, and AI startup Mercor. Separately, the popular [JavaScript package Axios was compromised](#) in late March in a targeted supply chain attack attributed to a distinct threat actor, demonstrating that the NPM ecosystem remains a high-value target across multiple adversary groups. Additionally, the popular text editing application Notepad++ disclosed that their [update infrastructure was compromised](#) by an advanced persistent threat (APT) with a highly sophisticated and unusually selective infection chain. [Industry reporting](#) attributed the attack to Chinese state-linked threat actors.
- Stolen F5 Big-IP APM vulnerabilities weaponized:** Chinese state-affiliated threat actors continued to capitalize on the October 2025 F5 corporate breach covered in our Q4 report. Our [BSL advisory published at the time](#) reviewed the disclosed vulnerabilities in depth and assessed that what were initially reported as denial-of-service bugs could be weaponized by well-resourced attackers to achieve remote code execution. That assessment proved accurate in Q1, when one of those CVEs (CVE-2025-53521) was [observed being actively exploited in the wild](#) for initial access. The CVSS score was subsequently upgraded and the vulnerability added to the CISA KEV catalog. BSL expects continued fallout from the October F5 breach as threat actors work through the stolen source code and vulnerability data exfiltrated during that incident.

While 2025 saw an ever-shortening "time to exploit" window for **discovered** vulnerabilities, 2026 begins with a dramatic rise in the number of critical vulnerabilities threat actors appear to be

crafting exploits for in the wild.

This trend appears to be linked to the impact that AI-empowered bug hunting has had on vulnerability discovery and reporting, with bug bounty programs [indicating a staggering 490% increase in reported bugs](#). We expect this trend to continue as the industry develops tools powered by models such as Mythos and cybercriminals race to enhance their own AI-assisted capabilities.



While these trends are concerning, exploit techniques have not fundamentally changed and as such, mitigation hasn't either. Critically, organizations have a much shorter window to apply vendor patches and should maintain a defense-in-depth security posture to reduce the impact of initial access.

As the pace accelerates, organizations must rethink how they respond to vulnerability exposure in an environment of rapid zero-day exploitation. If a system (particularly an edge device) was vulnerable during the exploitation window, organizations should assume potential compromise rather than relying solely on patching as remediation. In these cases, forensic review or incident response validation should be performed to assess whether the vulnerability was used for initial access or whether post-exploitation persistence mechanisms were deployed on vulnerable systems.

Emerging Ransomware Actors and TTPs

Beazley Security routinely engages victims of reported ransomware attacks through digital forensics and incident response (DFIR) and restoration services. As part of our response to these incidents, we capture data regarding trends and attacker behaviors. The following insights reflect what our incident responders observed through the first quarter of 2026.

Tracking threat actor leak site activity, we see that Qilin and Akira remained two of the most prolific ransomware groups this quarter. We also observed an uptick in cases from "Inc" and "Interlock" Ransomware operators.

Ransomware Investigations

Q4 2025

Q1 2026



Compared to the data we reviewed and published last quarter, Q1 exhibited a broader number of affiliate groups in action. The increase previously seen in independent or "Lone Wolf" operators faded away, perhaps indicating these operators have affiliated with more established ransomware-as-a-service (RaaS) platforms to leverage their proven tools to optimize efforts and address recent trends of decreasing ransomware payments.

Interestingly, DFIR investigations in Q1 identified multiple ransomware intrusions where threat actors exfiltrated data without encrypting data at rest in order to cause an operational impact to the ransomed organization. We observed this pattern across a subset of less prevalent affiliate groups that may favor simpler data theft extortion over the overhead of building and deploying ransomware. The shift could also indicate organizations are adopting stronger backup procedures and immutable solutions to defend against data destruction attacks, aiding restoration. [Other reports](#) also reflect a similar increase in data theft and extortion-only incidents the last half of 2025.

How Ransomware Attackers Gained Access in Q1

Mapping initial access methods across active ransomware investigations helps us identify patterns of entry and common hardening failures. While AI-empowered attacks grabbed headlines and impacted the developer ecosystem, evidence from ransomware intrusions in Q1 continues to show compromises driven by weak access controls on services exposed to the internet, which enable threat actors to leverage stolen credentials for initial access.

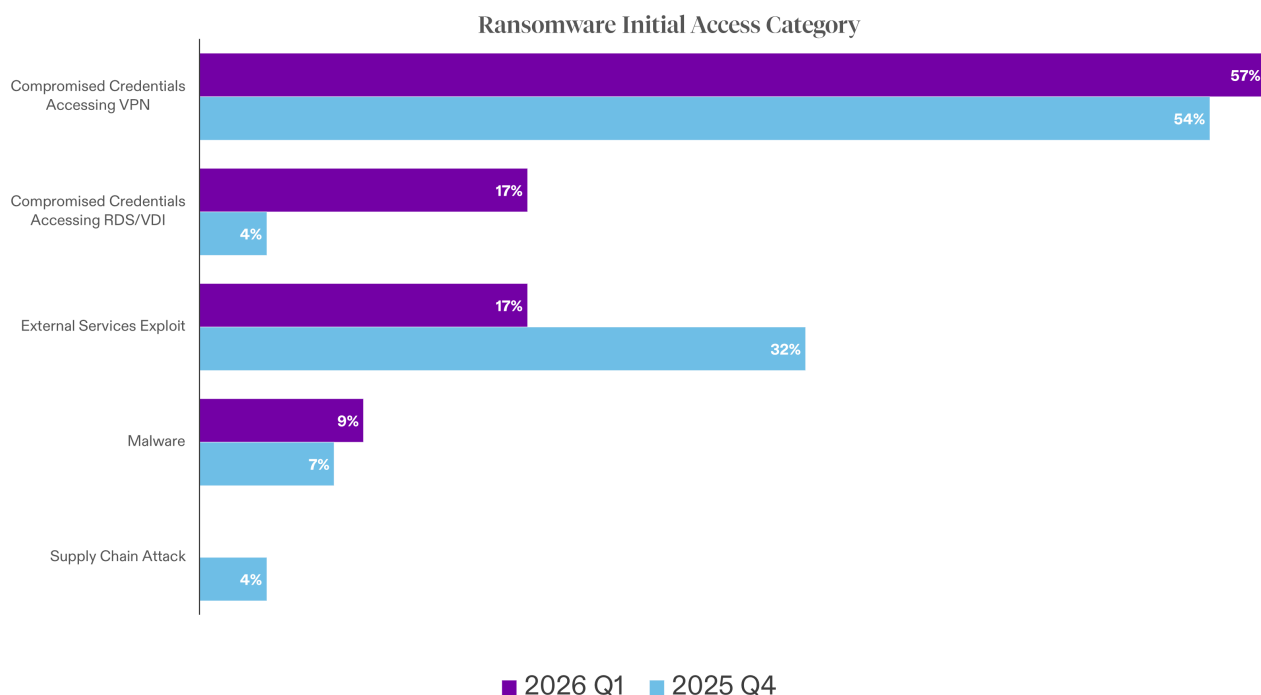


Figure 7: Ransomware Initial Access Category

Threat actors continue to succeed by using compromised credentials to breach victim environments. Paired with commonly targeted remote entry services such as VPN, RDP, and VDI platforms, attackers were able to consistently find a foothold into victim environments in 74% of incidents this quarter. While most ransomware deployments started with threat actors simply "logging in" instead of breaking in, exploit-driven access declined by 15% in observed incidents during Q1. It is typical for this category to adjust quarter over quarter depending on how successful and widespread a given 0-day campaign may become. Malware-related incidents were largely attributable to ClickFix campaigns, which deceive users into executing malicious commands to gain initial access. While BSL did not observe supply chain attacks culminating in ransomware deployment during Q1, recent partnerships between TeamPCP and ransomware operators suggest this vector may begin to surface in Q2.

Q1 2026 Ransomware Trends

Our telemetry and monitoring showed no significant month-over-month change in ransomware incidents or extortion-based leak site activity this quarter. If anything stands out, it's how little changed. The data shows that ransomware didn't need to change because it keeps working.

As illustrated below, reported ransomware incidents remain consistent over the last six months, aside from a dip in the holiday season that carried into January. The stabilization is contrary to [Q3 of 2025](#), especially when the breakout of campaigns by Akira caused a significant surge last August.

Trend of Reported Ransomware Incidents Last 6 Months

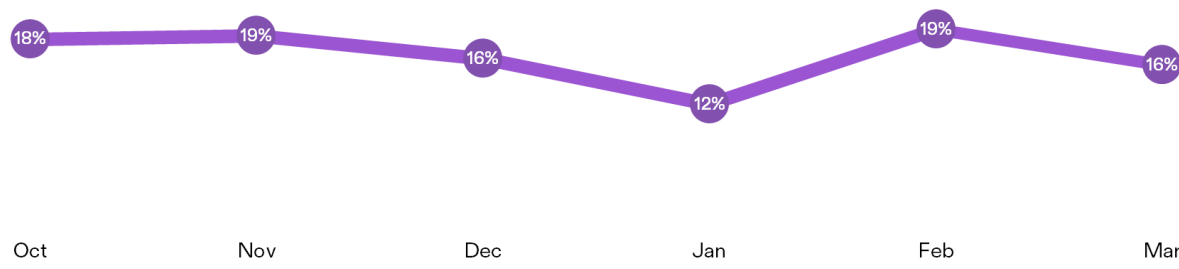


Figure 8: Reported Ransomware Incidents

Ransomware groups leverage leak sites to post victim identities and data as part of double extortion incidents, and monitoring this activity can signal the operational tempo of a given period across ransomware-as-a-service (RaaS) operators. The graph to the right captures this information from Q4 2025 into Q1 2026.

The number of posts observed remained steady quarter over quarter, with volume picking up significantly in March after a seasonal slowdown in attacker activity mentioned above.

Threat Actor Leaksite Posts

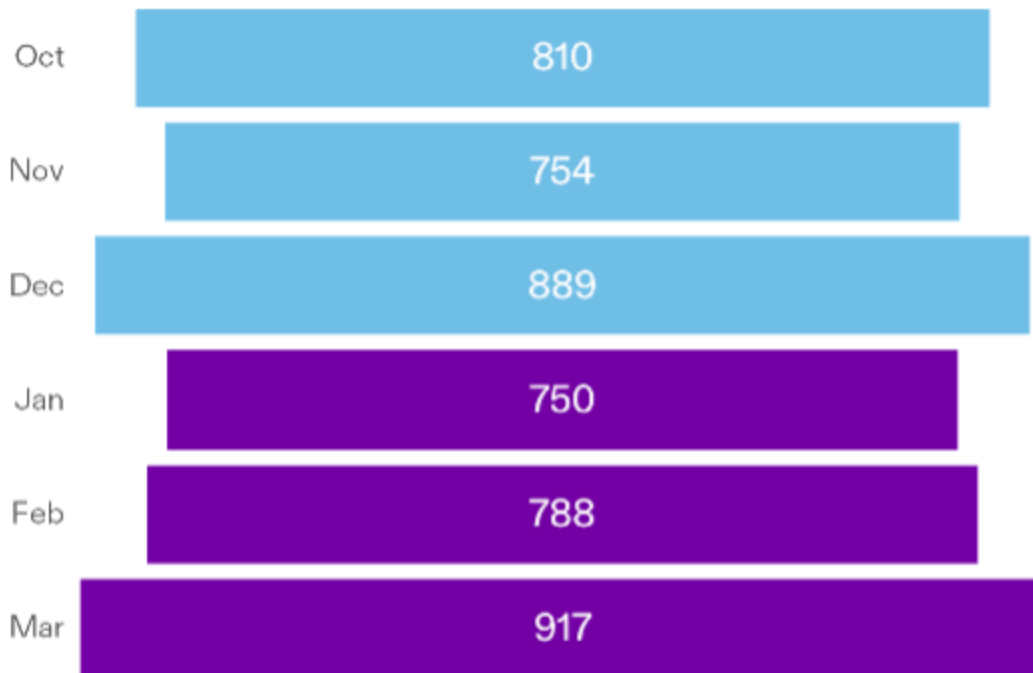


Figure 9: Threat Actor Leaksite Posts

Q1 leak site activity was concentrated to a smaller subset of known major players. The top three groups accounted for nearly 36% of all posts across known operators. Qilin was most active, with 419 public victim posts, significantly surpassing all other groups. The Gentlemen followed with 210 posts, and shortly behind them was Akira with 191 leak site posts.

Activity from the international law enforcement coalition [Operation Endgame](#) went quiet this quarter, with their last news update posted in late 2025.

Ransomware Impact Analysis by Sector

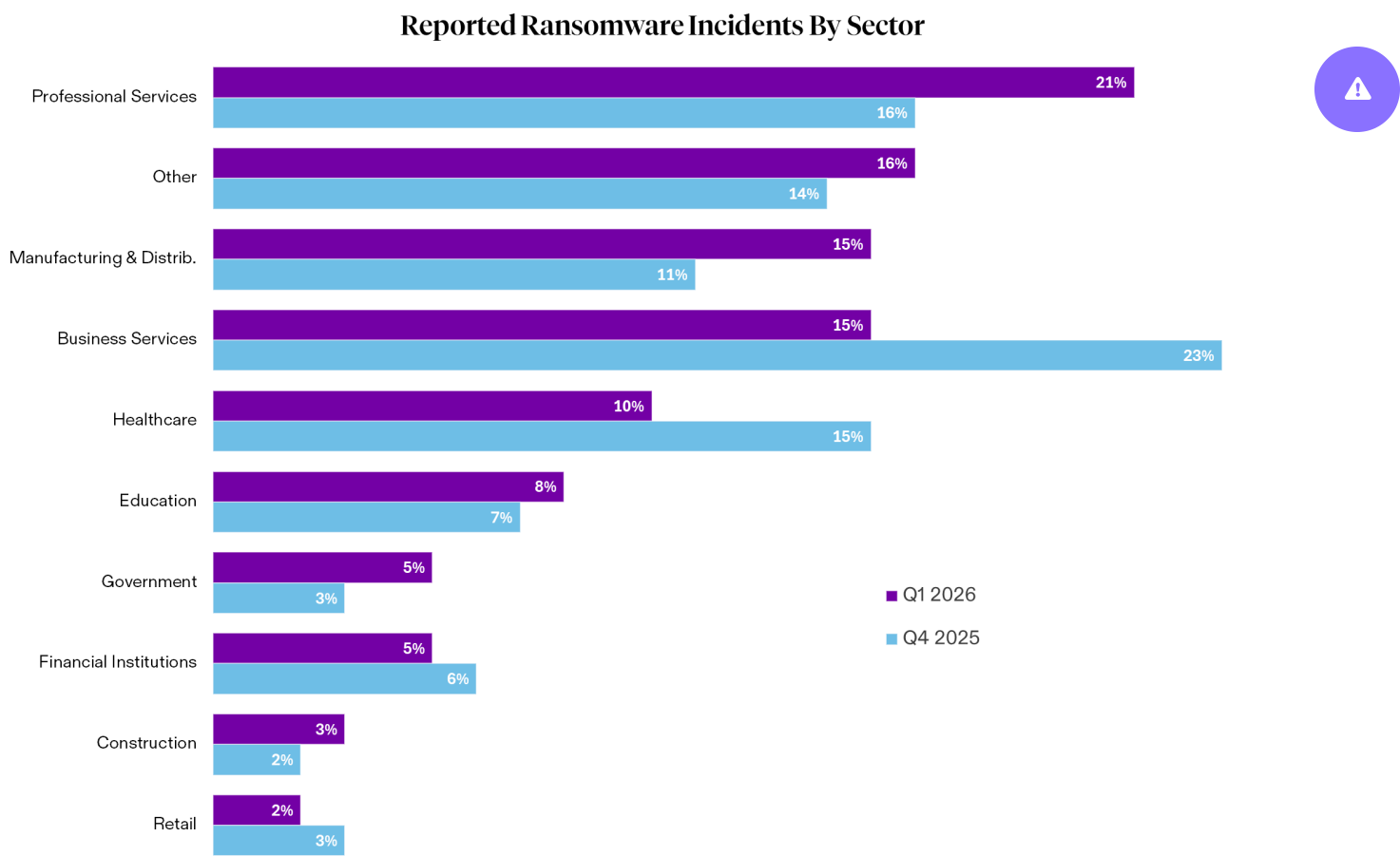


Figure 10: Reported Ransomware Incident By Sector

Professional Services took over as the most targeted sector in Q1, representing 21% of observed ransomware incidents, up from 16% in Q4 2025. Professional Services regularly accounts for a larger portion of reported incidents quarter over quarter, likely due to sensitive client data making entities in this sector high-value targets to threat actors and reporting less voluntary.

With a significant drop in reported incidents impacting Business Services, Manufacturing and Distribution rose to second on our list, with an increase in reporting from 11% to 15%. Reporting of incident distribution in other sectors remained mostly consistent, except for Healthcare declining from 15% to 10%.

We examine some of the specific ransomware groups observed from within Beazley Security's incident response engagements in the next section.

Q1 2026 BEC Trends

Business email compromise (BEC) remained one of the most frequently reported incident categories for Beazley Security in Q1 2026 and represented a significant share of DFIR engagements. These compromises usually leverage compromised credentials and sessions to access and manipulate inboxes and exfiltrate sensitive messages such as financial information or proprietary business communications. As a result, BEC attacks can go undetected for some time and scale across multiple victims in an organization.



The chart below highlights a distribution of reported BEC incidents by sector quarter over quarter.

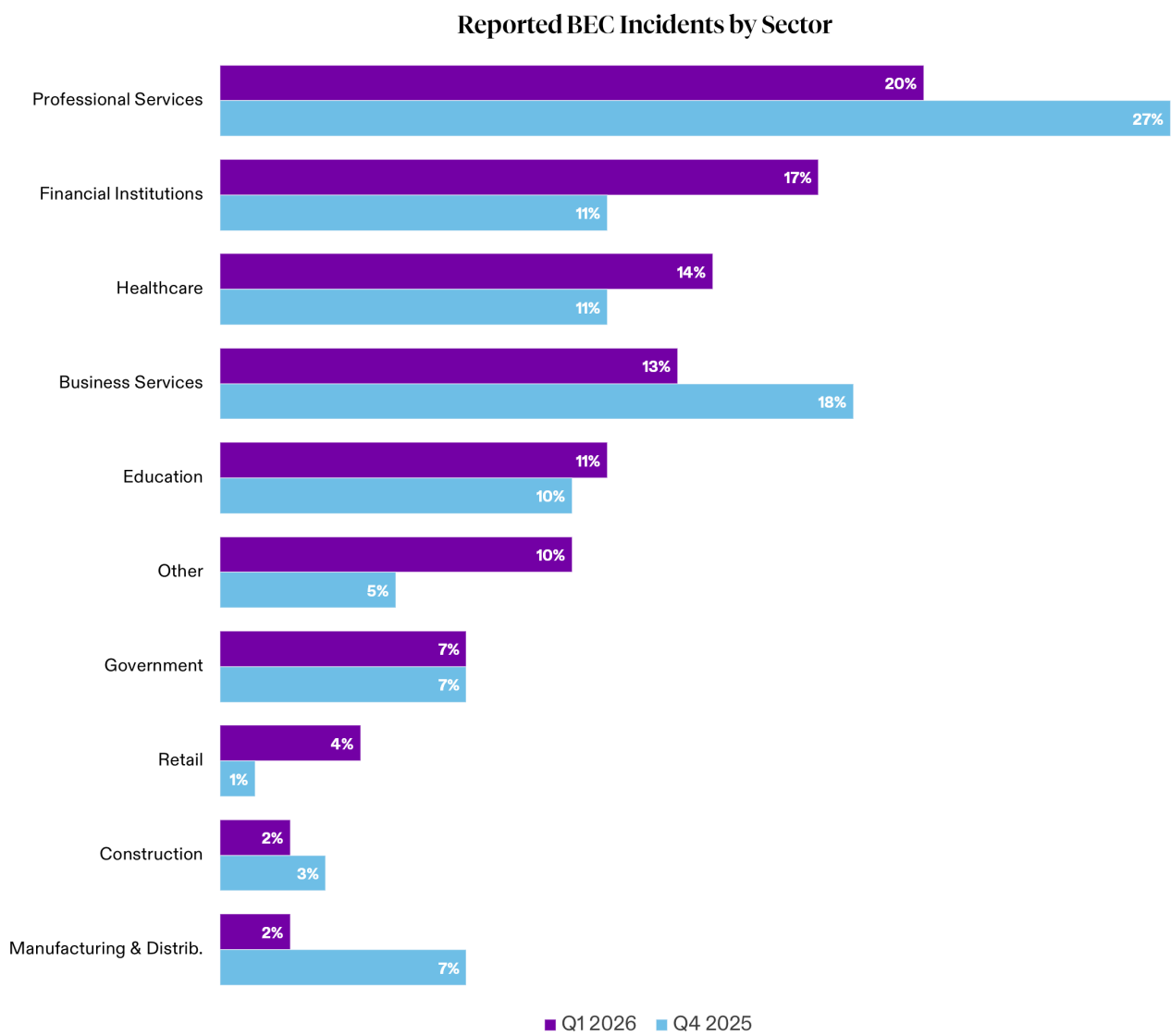


Figure 11: Reported BEC incidents by Sector

Professional Services and Financial Institutions accounted for a combined 37% of cases we investigated, representing the largest distribution this quarter. Both sectors are consistently targeted due to the high level of external client interactions and opportunity for payment redirection to threat-actor-owned accounts.

Healthcare incidents also increased from last quarter. The industry is commonly targeted to steal not just personally identifiable information (PII) but also protected health information (PHI), such as patient records, which can be more lucrative when sold on the dark web than other records.

Business Services and Manufacturing moderated compared to last quarter, while other major sectors stayed relatively the same.

Emails appearing to originate from trusted vendors represented the largest attack vector leading to compromise in BEC incidents handled by Beazley Security's incident response team. These incidents primarily involved two patterns: third-party vendor compromises where legitimate vendor email accounts were accessed and used to send malicious emails, and vendor impersonation where threat actors registered typosquatted domains to mimic legitimate vendors and direct victims to malicious attachments or credential harvesting sites.



Less common tactics included commodity phishing campaigns delivered through phish kits and executive impersonation. In approximately 53% of cases that Beazley Security responded to, organizations reported they had either fully or partially enforced MFA to protect email access, indicating that attackers are still able to circumvent these controls. As more organizations adopt some form of MFA to help protect accounts, attackers have adopted phish kits specially designed to collect additional factors of authentication and steal sessions. These adversary in the middle (AiTM) phish kits are designed to create a reverse proxy between the victim and a legitimate login page to intercept authentication attempts. Modern kits such as [Evilginx](#) are designed to clone legitimate login pages like Okta, M365, and Google and can be highly effective when paired with phishing impersonations. Defenders should regularly audit accounts in their environment for partially implemented MFA, and address accounts with MFA or conditional access exceptions. Adhering to modern MFA methods such as those offered by Microsoft Entra can help deter these attacks. Where transactional outcomes could be confirmed, nearly 32% of BEC incidents resulted in fraudulent transfers.

Beazley Security MDR Trends and Overview

Beazley Security regularly tracks adversary activity across monitored MDR environments to identify shifts in attacker targeting and behavior. Our MDR telemetry provides visibility into attacker techniques and tradecraft that can help inform and prioritize controls to defend against emerging attacks.

Telemetry this quarter revealed a shift in attack techniques from last quarter, with attackers targeting endpoints through adware campaigns and a resurgence of effectiveness in ClickFix social engineering attacks. The shift is illustrated with an increase in detected execution tactics, reflected in our MITRE ATT&CK tactic distribution to the right.

As documented in prior reports, ClickFix attacks leverage a living-off-the-land approach to fool users into executing obfuscated, malicious commands directly on the endpoint by copying and pasting them into a terminal or run dialog box. The attack has proven to be effective because it bypasses traditional proxy and browser security controls. This quarter, Insikt Group released a [detailed report](#) tracking the evolution and proliferation of this social engineering method into five observed clusters of attack.

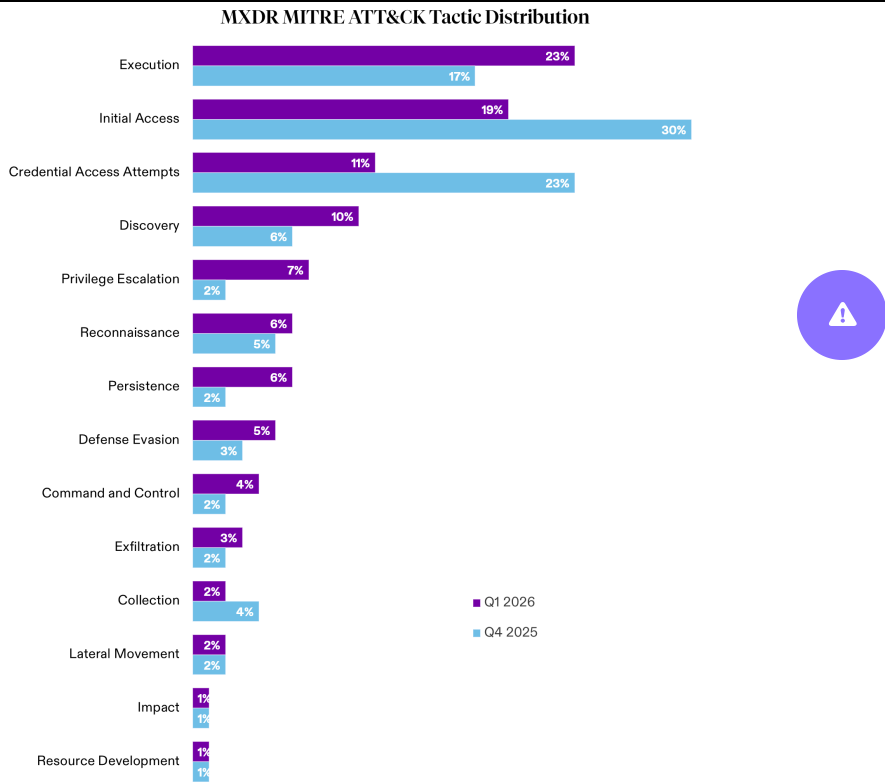


Figure 12: MITRE ATT&CK Tactic Distribution

Beyond ClickFix, the most prominent malicious installers and loaders making it to the endpoint were PDF-themed lures, with end users commonly tricked into downloading these variants directly to their desktop when detected. Threat actors often employ search engine optimization (SEO) poisoning to position these lures at the top of engine results.

In the table below, we break down a simplified quarter-over-quarter comparison into three simplified buckets that approximate where activity was detected in observed attack chains.

Attack Phase	Q1	Q4 2025	Descriptions
Early-stage Attacks	45%	65%	Credential access attempts, recon, and discovery activity detected and contained
Middle-stage Attacks	44%	27%	Attempts to sustain and expand adversarial control into environments contained

Attack Phase	Q1	Q4 2025	Descriptions
Late-stage Attacks	11%	8%	High-risk threats contained such as infostealer persistence, data exfiltration, and attempted ransomware deployment



During the quarter, early-stage detections fell to 45% from 65% in Q4 2025. The shift is mirrored in the increased detection of "middle-stage" activity and aligns with observed ClickFix style and SEO delivery techniques. These attacks place malware download attempts directly on the endpoint and bypass traditional browser-based controls, as documented in prior reporting of this section.

"Late-stage" attacks stayed relatively in line with last quarters distribution, reflecting consistent containment of higher impact threats like attempted execution of infostealers or detection of unauthorized remote access tooling. While controls in environments continue to limit attackers from executing critical impact events seen in late-stage attacks, the shift in distribution highlights the importance of maintaining effective security controls beyond initial access and perimeter threats, such as maintaining strong EDR posture and endpoint policy

Sources

- <https://labs.beazley.security/advisories/BSL-A1132>
- <https://labs.beazley.security/advisories/BSL-A1158>
- <https://labs.beazley.security/advisories/BSL-A1153>
- <https://labs.beazley.security/advisories/BSL-A1164>
- <https://labs.beazley.security/advisories/BSL-A1155>
- <https://labs.beazley.security/advisories/BSL-A1163>
- <https://labs.beazley.security/advisories/BSL-A1140>
- <https://evilginx.com/>
- <https://beazley.security/insights/quarterly-threat-report-third-quarter-2025>
- <https://www.sec.gov/Archives/edgar/data/310764/000119312526102460/d76279d8k.htm>
- <https://cert.europa.eu/blog/european-commission-cloud-breach-trivy-supply-chain>
- <https://riskandinsurance.com/cybercriminals-abandon-encryption-for-data-extortion-raising-stakes-for-risk-managers>

- <https://dailydarkweb.net/sportradar-bet365-and-fiba-data-exposed-in-vect-ransomware-breach/>
- <https://www.recordedfuture.com/research/clickfix-campaigns-targeting-windows-and-macos>
- <https://www.forbes.com/sites/zakdoffman/2026/01/20/irans-hackers-caught-using-elon-musks-starlink-to-attack-israel>
- <https://www.operation-endgame.com/>
- <https://fortune.com/2026/03/26/anthropic-leaked-unreleased-model-exclusive-event-security-issues-cybersecurity-unsecured-data-store/>
- <https://www.forbes.com/sites/jonmarkman/2026/04/14/how-claude-mythos-wiped-billions-out-of-cybersecurity-stocks>
- <https://xark.es/b/mythos-firefox-150>
- <https://cybernews.com/ai-news/hutchins-questions-anthropic-mythos-bug-hunting-ai/>
- <https://www.aquasec.com/blog/trivy-supply-chain-attack-what-you-need-to-know>
- <https://www.stepsecurity.io/blog/hackerbot-claw-github-actions-exploitation>
- <https://mashable.com/article/ai-discovered-zero-day-bug-reports-crisis>
- <https://www.coveware.com/blog/2026/2/3/mass-data-exfiltration-campaigns-lose-their-edge-in-q4-2025>
- <https://www.rapid7.com/blog/post/tr-chrysalis-backdoor-dive-into-lotus-blossoms-toolkit/>



More Insights

[View All >](#)

Quarterly Threat Report

Quarterly Threat Rep



Third-Party Risk Monitoring Factsheet

Beazley Security's
Third-Party Risk Monitori...

Quarterly Threat Report: First Quarter, 2026

The first quarter of 2026
started with a lull and...

Quarterly T Report: For Quarter, 20

A majority of rans
activity resulted i



beazley security

[Solutions](#)

[Company](#)

[Resources](#)

[Beazley
Clients](#)

[Contact
us](#)



Privacy Policy

©2026 Beazley Security is a wholly owned subsidiary of Beazley plc, providing cyber security services. Beazley Security does not provide insurance products or services, nor does it provide legal services or advice. Customer information may be shared between Beazley Security and Beazley plc and/or its affiliates and subsidiaries; however, such information will not be used to inform the underwriting or claims decisions of any Beazley insurance affiliate, unless the customer agrees to disclose such information for that purpose.